

PERSPECTIVE

Social Engineering Analysis Framework: A Comprehensive Playbook for Human Hacking

WOJCIECH NOWAKOWSKI^{ID}

NASK-National Research Institute Warsaw, 01-045 Warsaw, Poland

e-mail: wojciech.nowakowski@nask.pl

ABSTRACT Social Engineering attacks are among the most exploited methods in today's cybersecurity threat landscape. Despite the impact and the volume of such incidents, there is still a surprising lack of comprehensive tools or frameworks offering an in-depth insight into Social Engineering attacks. The paper delivers a handy yet comprehensive framework for the analysis of the Social Engineering tactics, techniques, and procedures (TTPs), distinguishing six major phases of the Social Engineering process, together with detailed TTPs linked with each of them. In the long-term, it may lead to devising better and more effective defense mechanisms against such attacks by providing an in-depth insight into the process and methods behind them. The outcome presents that framework in the form of a legible, transparent, and ready-to-use matrix, similar to the MITRE ATT&CK matrix. The paper also contains a cross-comparison between the proposed framework and the MITRE ATT&CK to underline the added value of the proposed approach. In order to demonstrate the practical usefulness of the approach proposed in this paper, after formulating the entire framework, we apply it to decompose and analyze in detail some real-life Social Engineering scenarios.

INDEX TERMS Social engineering, cybersecurity, human factor in security, cybercrime, cyber awareness.

I. INTRODUCTION

In today's cybersecurity landscape, it is a well-established fact that a human factor is often perceived as the most vulnerable element of the cybersecurity system. Social Engineering (SE) attacks, meaning the attacks that take advantage of human behavioral vulnerabilities, especially in connection with software design that does not take these vulnerabilities (often being a *natural* human behavior) into account [1], were among the most frequent even before the COVID-19 pandemic. The pandemic resulted in yet another surge of cybersecurity incidents involving a human factor [2]. The popularity of these tactics among various threat actors is a product of several factors. These attacks are relatively cheap and easy to execute. They are feasible even without an elaborate technical background or knowledge. Most important of all, they are very effective.

The associate editor coordinating the review of this manuscript and approving it for publication was Derek Abbott^{ID}.

Despite the frequency and impact of SE attacks, there is a surprising shortage of tools or frameworks that could be useful in gaining a better insight and understanding into the various tactics, techniques, and procedures (TTPs) employed in different scenarios and schemes related to SE. The most prevalent cybersecurity frameworks, such as MITRE ATT&CK [3], or Lockheed Cyber Kill Chain [4], tend to focus primarily on the technological aspects. For instance, out of around 200 various techniques listed in MITRE ATT&CK Enterprise Matrix, only 6 of them refer directly to various Social Engineering techniques. Cyber Kill Chain does not provide many details about Social Engineering either. Both these frameworks limit themselves just to stating that Social Engineering can be used in various stages of cyber attacks. However, they do not delve into more intricate aspects and nuances of Social Engineering, such as creating a rapport between the attacker and the victim (for the sake of simplicity, we will use the terms 'victim' and 'target' interchangeably) or multi-stage SE attacks. In fact, we will try to demonstrate, referring to some real-life

scenarios [5], that it is possible to compromise the security of information based solely on Social Engineering without employing nearly any of the technical TTPs described in the MITRE ATT&CK matrix. The existing cybersecurity frameworks fail to capture the essence of such attacks, which leaves space for creating a separate toolbox or framework dedicated to Social Engineering attacks. The main goal of this paper is to present a proposal for a framework designed specifically for the analysis of Social Engineering, which would also cover the aspects of SE attacks that are omitted by Cyber Kill Chain and MITRE ATT&CK.

The rationale behind the idea of introducing such a framework is identical to the one standing behind the idea of ethical hacking. On the one hand, one might argue that describing such things in detail might provide potential threat actors with a convenient handbook as to how to exploit a human factor. On the other hand, gaining a better understanding of the mechanisms underlying various Social Engineering methods might prove to be essential in order to devise effective defenses against them [6].

The main long-term goal of this paper is to contribute to developing effective and efficient defense mechanisms and enhancing situational awareness concerning Social Engineering threats. Providing detailed information and a catalog of Social Engineering Tactics, Techniques, and Procedures, first of all, might give a better understanding and insight into the perspective of the threat actors using these TTPs. That might enable the defenders (and the victims) to foresee the potential actions of the attackers and counter these actions or at least be prepared for them. In the long run, based on that insight, hopefully, it might be possible to design better defenses or responses to particular TTPs, both on an organizational (i.e., in the form of policies, procedures, or technical solutions) and individual (i.e., by developing a threat awareness and supporting the notion of critical analysis of various influence techniques used by the attacker).

Currently applied defense mechanisms against SE attacks mostly revolve around procedures and policies on an organizational level and user vigilance on an individual level [7]. Some technical solutions for detecting suspicious phishing emails or malicious email attachments have also been developed [7]. However, the rising number of SE attacks proves these measures to be often insufficient. Therefore, on some abstract level, the goal of this paper is also to raise situational awareness among security architects and developers in order to take into account Social Engineering threats when planning security systems, hopefully, to make them secure *by design*.

Already invoked MITRE ATT&CK decomposes the attacker's technical TTPs into *prime elements* and continues to associate each of these *elements* with respective detection and mitigation techniques, thus creating easy-to-follow and implement guidelines on how to defend against each attacker's technique. Similarly, the framework introduced in this paper aims to provide the first step of that process with

respect to Social Engineering TTPs, forming a solid basis for further developing the following steps, namely designing detection and mitigation methods associated with each attack technique (which would require further studies and research also involving considerable input from cognitive science and psychology).

The paper is organized into the following sections: Section II provides the overview of the current state of the art in this domain, Section III presents a methodology used to construct the framework, Section IV introduces the Social Engineering analysis framework and explores it in detail, Section V shows a comparison between the framework formulated in this paper and the MITRE ATT&CK in order to exhibit the innovative character of the idea presented by us and its real added value, Section VI demonstrates how the framework can be applied in decomposing some of the real-life attack scenarios and Section VII contains the conclusions of the paper, as well as some recommendations for future studies.

II. RELATED WORK

Despite the vast collection of works on Social Engineering, there is a surprising scarcity of papers attempting to provide a holistic overview of this problem. The most notable one is the work by Montanez and Xu [6], which introduces a MITRE-ATT&CK-like framework for decomposing and analyzing Social Engineering attacks. The framework presented in the cited paper is quite comprehensive and multifaceted. However, at some points, it suffers from overgeneralizing and does not delve into the nuances and details of the various TTPs it presents. Particularly, it does not address certain psychological mechanisms that lay at the foundation of SE TTPs. Therefore, in this regard, the framework we proposed is primarily aimed at providing a complementary view to the one presented by Montanez & Xu.

In terms of work dedicated to tackling the issue of defenses against SE attacks, it is worth mentioning the paper by Montanez et al. [7]. It provides a general overview of methods devised to address and mitigate certain threats posed by Social Engineering, both in the domain of cyberspace and in the physical world, as well as in the area where these two spheres mingle together.

There is also a considerable number of bibliography positions on SE in general. Article [8] presents a new approach to provide a comprehensive taxonomy of SE attacks and corresponding defense mechanisms based on both a literature survey and an analysis of real-life attacks and incidents. Paper [1] gives a good insight into the evolution of Social Engineering and some of the most common concepts related to that field. Several other authors have done some work on defining and describing various granular Social Engineering TTPs. For instance, [9] provides an in-depth analysis of methods used in phishing. References [10] and [11] focus on recent developments in spear phishing tactics used by the threat actors. Reference [12] delivers valuable insight into the issue of baiting.

It is also impossible to talk about Social Engineering without mentioning one of the most fundamental authors in this field - Mitnick and Simon [13]. In his works, he provides a very insightful guide to leveraging various SE techniques in order to convince people to perform the actions desired by the potential attacker.

Given the fact that Social Engineering takes advantage of human psychology and various techniques to influence it, it is essential to evoke one of the most prominent work on psychological and social aspects of persuasion and influence, namely, the book by Cialdini [14], where he introduces the main six principles for inducing an influence on people.

Another crucial work, setting foundations for academic research on Social Engineering, is a book by Hadnagy [15]. He delivers a general overview of SE methods used by real-life threat actors, as well as some scientific background for these methods.

It is also worth mentioning a number of commercial reports concerning the volume and impact of SE attacks in real life, such as [16], [17], or [18]. Although they vary in terms of scope or time frame, they agree on one thing, which is the fact that Social Engineering threats are on the rise, and this trend will continue in the foreseeable future. Especially in the wake of the rapid development of AI-enabled tools and technologies, which may open even more avenues for exploiting the human factor in cybersecurity [11]. This fact also gives another justification for the need for a comprehensive and multifaceted study on Social Engineering attacks.

In summary, although the particular Social Engineering TTPs are well-researched, the main gap in the current state of the art in this field is a lack of a comprehensive and holistic framework that would put all those granular elements together. Such an approach would embed these TTPs in a wider context, thus providing a better insight.

III. METHODOLOGY

The methodology of the research behind the framework is based on threefold foundations.

First, we conducted a thorough literature survey on this subject matter. We focused on both a high-level overview of the SE attacks and trends, as well as low-level granular research on particular TTPs or methods. Section II provides just the most appropriate and the most important works selected by us from the plethora of papers reviewed during the literature survey.

Second, we analyzed numerous real-life SE attacks based on publicly available information, such as the ones enumerated in Section VI. In order to better understand the *modus operandi* adopted by some malicious actors, we attempted to break down the TTPs employed by them into atomic elements. Then, based on our literature review, we tried to categorize these TTPs, which enabled us to compare different scenarios in a more systemized manner.

Third, it is the professional experience of the authors. In the course of the professional career in the branch of information

security, the authors of this paper had an opportunity to execute hundreds of Social Engineering scenarios (e.g. during penetration tests) and Red Teaming operations in real life, in a variety of different environments and circumstances. First-hand experiences and lessons collected from these scenarios provided valuable and actionable insights as to how various SE methods work in practice. These ordeals also brought our attention to a lack of a unified approach or framework to describe and analyze SE scenarios. We have noticed that in our work, such a tool would be particularly useful for planning such activities, as well as analyzing them *ex-post*. This incited us to develop some first drafts of the framework presented in this paper, which we were using to systemize the preparation and evaluation of our professional activities. Our experiences proved that such an approach is very effective and provided data that helped us to refine the formulation of the framework. We also enriched the collected data with insights from other SE professionals and practitioners. Their opinions provided us with a wider collection of different perspectives. It also enabled us to confront our ideas with the experiences and perceptions of other experts.

IV. FRAMEWORK FORMULATION

This section contains the formulation of the framework. First, a general structure of the Social Engineering Analysis Framework is presented. Then it proceeds to explore and decompose each stage of the proposed framework in detail into *prime elements*, introducing some of the techniques and procedures associated with each stage - in a manner similar to the MITRE ATT&CK matrix [3]. We also try, whenever possible and applicable, to enumerate some of the most relevant defense mechanisms related to particular TTPs.

A. GENERAL STRUCTURE OF THE FRAMEWORK

Before continuing with the structure of the framework, it is essential to emphasize one core assumption underlying the very idea of this framework.

The majority of existing frameworks or tools acknowledge the importance and potential impact of Social Engineering techniques and methods. However, as was already outlined in the Introduction, these frameworks do not delve into details and nuances of Social Engineering methods. Moreover, these frameworks also usually treat Social Engineering as separate events that happen at a certain point in time. As we shall show in this paper, such an approach strips the analysis of SE attacks from much of its potential depth and insight.

Instead, this paper offers an alternate perspective on Social Engineering, viewing it primarily as a process. Such a process of events - or stages/phases - that leads to a successful SE attack usually starts well before the actual incident. In some cases, this process also continues for long after the initialization of the incident, compromising the security of information. It suffices to invoke some examples of nowadays phishing campaigns, which are becoming more and more sophisticated, often involving several stages [19]. Therefore, in order to fully grasp the potential complexity of Social

Engineering attacks, it is essential to accept the notion of SE attacks as a process. Furthermore, it would enable the devising of more elaborate defense mechanisms against Social Engineering at each stage of the process, similar to the idea of Defense in Depth [20]. Last but not least, unlike existing frameworks, like MITRE ATT&CK, this approach allows for a better understanding of intricate mechanisms, e.g. psychological principles underlying particular SE methods, rendering them to be so effective.

The very idea of constructing this framework stands on twofold foundations. On the one hand, it stems from the academic approach to SE set by Hadnagy [15]. On the other, it comes from multiple interviews with Social Engineering experts and practitioners representing various backgrounds and perspectives, as well as from the professional experience of the authors. Combining these two inspirations led the authors to devise the framework and decompose it into particular stages outlined below.

In this paper, we would like to introduce the following structure of a Social Engineering attack comprising six consecutive stages/phases:

- 1) Reconnaissance
- 2) Preparation and Weaponization of Information
- 3) Initial Contact
- 4) Establishing a Rapport
- 5) Exploitation
- 6) Post-Exploitation

In brief, the usual path of the Social Engineering attack follows the stages outlined above, starting with a reconnaissance and gathering information about the potential victim. Once that information is collected, it forms the basis for crafting an appropriate cover story for the attack, matching the behavioral and psychological profile of the victim, together with developing the necessary resources or infrastructure. Next, the attacker initiates contact with the victim based on the cover story and resources from the previous stage. Then, the perpetrator seeks to establish some form of rapport with the victim in order to more easily exploit them - which usually takes the form of convincing them to perform some action desired by the attacker. Finally, after having exploited the victim, in the post-exploitation phase, the attacker might seek to perform different types of actions, depending on their ultimate target, varying from terminating the contact to even utilizing the established contact to gain a foothold or additional backdoor to the infrastructure of the target organization.

Furthermore, to add another layer to that structure, certain actions performed by the attacker and the information gathered by them in the process allow them to reiterate back to some of the previous phases, potentially opening new possibilities or enabling new TTPs to be used. Once the attacker enters into an interaction with the potential victim, the attacker can gather some additional information, i.e. based on the behavior of the victim. That allows the attacker to enrich the information on the victim collected during the reconnaissance (or during other phases of the attack), which,

in turn, can result in adopting new techniques or procedures by the attacker that would be more effective against the target exhibiting particular psychological profile [6]. This idea, which will be discussed in detail in later subsections, is presented in Figure 1.

B. RECONNAISSANCE

Just as with *regular* cyberattacks, whose workflow is neatly described by Cyber Kill Chain [4] or MITRE ATT&CK [3], the first stage of Social Engineering attacks is the reconnaissance.

Good reconnaissance is crucial for planning any operations, both in the physical and in the cyber world. This fact has been well-known already for centuries. For instance, it was thoroughly discussed in *The Art of War* [21]. Unsurprisingly, modern cybersecurity frameworks also acknowledge the importance of collecting solid intelligence before engaging in actual actions [3]. The main goal - on the part of the attacker - of this stage is to gather as much information about the victim or the target as possible. These data are used to create a profile of the victim, identify potential behavioral vulnerabilities, weak spots, and hooks for further stages.

It is possible to distinguish several techniques that can be leveraged to gather information on the potential victim:

1) OPEN SOURCE INTELLIGENCE

Open Source Intelligence (OSINT) 'is the intelligence discipline that pertains to intelligence produced from publicly available information that is collected, exploited, and disseminated in a timely manner to an appropriate audience for the purpose of addressing specific intelligence and information requirements' [22]. In the era of the digital world and Big Data, OSINT is primarily, but not exclusively, focused on online resources [23]. The side effect of the progressing digitization of multiple spheres of life is the growing accessibility of very diverse information on the Internet, with social media being one of the most noteworthy examples (social media as a source of information will be discussed in a separate section). Therefore, the usual problem in OSINT these days is not a lack of information but rather the need to filter out the most important and relevant pieces from the large sets of available data. OSINT practitioners have developed a specialized set of skills and tools in order to effectively browse through various types of sources in search of information, varying from contact data (email, phone number, address, etc.) to professional information (workplace, business email addresses, coworkers, business email headers and footnotes, etc.) up to some more private ones (hobbies, interests, friends, family, etc.) [23], [24].

Due to the vast diversity of OSINT sources and their ever-changing nature, it is difficult to provide one set of tools or techniques that are useful for OSINT. However, [24] and [25] provide one of the most comprehensive overviews of tools for OSINT.

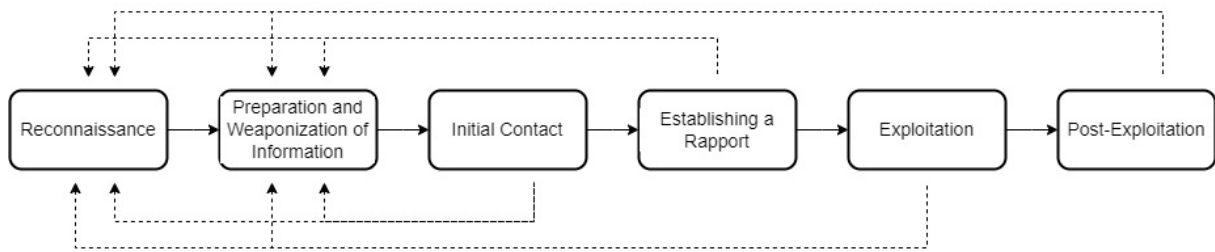


FIGURE 1. The workflow of social engineering process.

The most efficient defenses against OSINT-based reconnaissance are: cyber hygiene and cyber awareness training, including limiting online presence and the scope of information available on the Internet [22].

2) SOCIAL MEDIA INTELLIGENCE

Social Media Intelligence (SOCMINT) denotes the intelligence collected through social media (that is, platforms such as Facebook, X (former Twitter), TikTok, Instagram, LinkedIn, VK, etc.) [26]. Originally, it stemmed from OSINT, but due to the fact that social media have become such a vast and complex subject of study, and due to the fact that they require some setting up an account and logging in to access most of the contents (which renders them not fully *open* sources), SOCMINT has evolved into a separate discipline.

Although the social media platforms vary a lot between each other in terms of preferred means of expression, target group, or type of information published - LinkedIn is primarily aimed at professionals and is more *formal*, TikTok is based on short videos, with its target group being the youth and teens, Instagram serves mainly to publish photos and X is useful for sharing text-based information, while Facebook (and its Russian equivalent - VK) contains a versatile mix of all these characteristics - they share one common feature. Namely, they are a *goldmine* of information on people and organizations. SOCMINT enables potential attackers to gather a vast collection of data about both personal and professional aspects of a potential victim.

For instance, TikTok and Instagram can be used to gain insight into one's material status, hobbies, interests, travels, or even private houses. LinkedIn provides data on a potential organization, its structure, other coworkers, and sometimes even technologies or solutions used in a particular company. X and Facebook often deliver valuable insight into individual's personal and political views, as well as information on closest friends and relatives. All this information put together can form a solid basis for constructing a psychological profile of a potential victim [6].

Similarly to OSINT, the best countermeasures against SOCMINT include cyber awareness and cyber hygiene trainings, with a special focus on limiting or carefully balancing the quality and the quantity of information posted on social media platforms [26].

3) DATA LEAKS

Data leaks usually contain information that is not publicly available or accessible, often of sensitive nature [27]. The contents of particular leaks may vary. They often consist of data such as logins, passwords (either hashed or in plain text), or user personal data. These data, put together with information from other sources (i.a. OSINT, SOCMINT, etc.) might provide additional angles for gathering intelligence on a given target, e.g. access to victim's accounts on online platforms.

There are multiple sources enabling access to leaked data, such as Pastebin [28] and many of its variations, hacker forums, or Darknet (the use of Darknet is explored in more detail in Section IV-B6), to name just a few.

Although an average Internet user cannot do much to prevent data leaks themselves, basic cyber hygiene and rules of safe behavior online (e.g. using secure and unique passwords for each platform/service) can indirectly mitigate the risks stemming from potential data leaks.

4) PUBLIC RECORDS

Another potential source of valuable intelligence is public records. This source is heavily dependent on local legal regulations. In some countries, there are multiple registries available to the public (in numerous cases, they are also available online), such as company, entrepreneurship, land, mortgage, car, and vehicle registers. Each of them may provide potentially useful information on i.a. material status, relatives, and social links of the potential target.

Given that transparency of public records is usually regulated by legal provisions, little can be done to limit the scope and availability of these data. Therefore, there is no clear mitigation strategy against this technique.

5) DUMPSTER DIVING

Dumpster diving is one of the techniques associated with Social Engineering that requires physically digging through dumpsters and trashcans of the target in search of some potentially mishandled sensitive information [29]. The scope of information that could be acquired through dumpster diving is very broad - from bank statements, through private or business notes, up to even some old hard drives or devices. In essence, everything that is not adequately utilized and

is thrown into garbage, can potentially be recovered by the attacker.

Limiting the amount of data leaked through waste can be achieved, e.g. through security awareness training on the level of an individual person and with appropriate security and risk management procedures on the level of an organization.

6) DARKNET

The Darknet (or Dark web) is the part of the Internet that is not accessible through standard browsers and is not indexed by them. The Darknet can be entered via TOR or other dedicated tools [30]. The dark web is most commonly known as a marketplace where one can purchase almost anything, like drugs, CSAM (Child Sexual Abuse Materials), weapons, or even hire a murderer [31]. In the domain of cybersecurity, the Darknet has gained notoriety as a place where malware, data leaks, and Cybercrime-as-a-Service are offered on a daily basis. In the context of SE attacks, the attacker might leverage these possibilities not only in the reconnaissance phase but also on other stages of the attack.

It is difficult to indicate an efficient defensive mechanism against this technique. To some extent, cyber awareness and cyber hygiene might influence the level of exposure online. However, by no means they cover the entire scope of threats linked with the Darknet.

7) SOCIAL ENGINEERING FOR RECONNAISSANCE

As outlined in the introduction to this section, SE attacks may also be performed in an iterative loop or cascade, where one attack serves only as a means to gather intelligence and resources needed for another attack. In theory, that loop may even be infinite, though it may be hard to imagine such a scenario. For instance, the goal of the primary attack may be to collect first-hand observations or sensitive information about the potential victim that could be used to craft the actual attack.

MITRE ATT&CK matrix covers this technique to some extent with its T1598 - Phishing for Information technique [3]. However this notion should be understood more broadly without limiting itself just to phishing, as it is just one of the possible SE attack vectors used to gather more information on the target.

In a similar manner, SE attacks could be used for preparation and development of appropriate resources for the actual attack or even for initiating contact with the victim, i.e. by gaining access to a legitimate account through Social Engineering (it is further explained in the next section) or by orchestrating a reverse SE attack (more on that in a section about initial contact). For the sake of simplicity and clarity, we will not repeat the same point in the next sections, but one should bear in mind the notion of the use of SE attacks as a means to obtain intelligence, deepen the reconnaissance, or provide necessary resources.

The catalog of potential countermeasures against this technique covers, in fact, all defensive techniques, as it

depends on a particular SE scenario used by the attacker in this case.

C. PREPARATION AND WEAPONIZATION OF INFORMATION

In this stage, the attacker uses the information gathered during the reconnaissance to craft the attack scenario - one that would best appeal to the victim's psychological profile - together with the necessary resources and infrastructure to conduct the attack.

From the viewpoint of the attacker, this phase is also crucial in terms of Operations Security (OPSEC) - meaning different types of measures aimed at providing anonymity and security. Some of them, i.e., the use of Virtual Private Networks and Servers (VPNs and VPSes), TOR network, or burner phones, are rather elementary in retaining anonymity online and, therefore, are more or less independent of the particular attack scenario. Other OPSEC techniques, on the other hand, depend on a given situation and may vary on a case-to-case basis.

The attackers employ several techniques to create a credible appearance that would inspire trust in the potential victim:

1) FAKE IDENTITY

Fake identity is an essential element of the attacker's OPSEC. It provides a vital safeguard from revealing the attacker's true identity, which in turn minimizes the risk of facing potential consequences. It is also a basis for building a cover story used in the later stages of the process.

The detail and complexity level of the bogus identity can be very different, depending on the requirements of the given scenario. In some cases, just a fake name and position or function might suffice. In contrast, in other schemes, a comprehensive identity with all the social IDs and fake personal, professional, and educational backgrounds could be required.

Several portals exist which can generate fake identities automatically with the chosen level of detail [32], but this process might as well be done *manually*.

In the physical world, enacting a fake identity might sometimes require the use of props (e.g., business cards, fake ID card, fake police badge, food delivery bag, etc.) and outfits (e.g., food delivery or police uniforms).

Several methods can be used to address the use of fake identities. On a level of an individual person that would involve some basic vigilance and cyber awareness. On a level of an organization e.g. appropriate identity and access management procedures can limit the usefulness of a bogus identity.

2) FAKE ACCOUNTS

Creating fake accounts, such as email and social media accounts, has two primary purposes.

First, they are instrumental in building up the credibility of the attacker's fake identity. These days, almost everyone

has some online presence - at least in the form of an email account. Therefore, creating an email account associated with the bogus identity makes that identity appear more authentic.

In addition, the attacker might further improve the credibility of such an identity by creating some social media accounts associated with the given identity. However, creating and maintaining a social media account that appears *legitimate* might require considerably more effort than setting up an email account. In fact, the amount of work that has to be done depends strongly on a particular social media platform and its characteristics.

For example, creating a LinkedIn account and achieving a milestone of 500+ connections (the exact number of connections exceeding 500 is not visible for non-premium users) is quite tedious, but keeping it alive does not require much effort, as most LinkedIn users are relatively passive in terms of posting or reposting anything. On the other hand, in order to maintain a legitimate-looking Facebook or X account, the attacker needs to be regularly active in posting (or at least reposting) some new information or entries.

Second, these accounts might also serve as means of communication with the victim (that notion is further discussed in a section on initial contact) - depending on the assumptions of the particular attack scenario.

From a technical perspective, creating fake accounts does not require any advanced skills or tools. Some platforms might be suspicious of the use of VPNs when setting up an account. Nonetheless, it is possible to create such an account without hindering OPSEC, for instance, by using publicly available Wi-Fi.

Just as with fake identities, user vigilance and awareness are the best available defense mechanisms. When encountering a new person or organization online, it is worthwhile to conduct some basic OSINT and SOCMINT checks on that person/account. Some of the fake accounts, if not set up properly can often be easily identified with just a basic background check.

3) LEGITIMATE ACCOUNTS

The attacker may also obtain access to a legitimate account, for example, by brute-forcing login data, using leaked credentials, or through a previous Social Engineering attack (hence the notion of the reiterative loop of SE attacks). Using such an account for further SE attacks boosts the credibility of the attack scenario, as the potential victim is naturally more prone to trust a message from an already known account (which is strongly connected with the Impersonation technique).

It is also possible to gather legitimate email information, i.e., email headers and footnotes. For instance, that information could be collected through a SE attack itself (T1598 of MITRE ATT&CK - Phishing for Information [3]). Having harvested these data, the attacker might use them to craft a legitimately-looking email message with authentic headers, footnotes, etc., that would be difficult to distinguish from a genuine email.

Protecting credentials or access to legitimate accounts can be achieved through a plethora of mutually overlapping methods, such as implementing multi-factor authentication (MFA) or employing a secure password policy, [8].

4) IMPERSONATION

Impersonation means pretending to be an existing person or organization [33]. Unlike fake identity, in the Impersonation method, the attacker uses an already existing person or organization instead of inventing the identity from scratch. In order to be effective and credible, impersonation often requires access to that person's (or organization's) legitimate accounts (see Section IV-C3) or spoofing them (see Section IV-C5).

Similarly to enacting a fake identity, physically impersonating someone may involve the use of appropriate props and outfits.

Mitigation techniques against impersonation are generally equivalent to those used in cases of legitimate accounts, fake accounts, or domain spoofing and typosquatting, [8].

5) DOMAIN SPOOFING AND TYPOSQUATTING

Typosquatting denotes creating a domain that is similar to the target domain so that it can easily be mistaken for the original domain [34]. That domain can be used i.e., to host a malicious website or to provide an email address that would appear almost identical to the legitimate email.

Creating such a domain is very easy, even for non-technical individuals, as it generally requires searching for an available domain and registering it with a domain registrar.

Similar results can be achieved through DNS Spoofing, that is manipulating Domain Name System (DNS) records in order to redirect the victim's traffic to a fraudulent website created by the attacker. DNS Spoofing can be achieved in several ways, i.e., through DNS cache poisoning [35]. On the one hand, spoofing DNS records can be even more effective than typosquatting because it does not require creating a legitimate-looking domain name and the attacker does not have to convince the victim to access the fake website instead of a real one. On the other hand, DNS Spoofing is much more challenging to achieve and it involves some considerable technical skills and knowledge.

The best and perhaps the only defense against typosquatting is cyber awareness, in particular concerning careful evaluation of website addresses. In case of DNS Spoofing and using a spoofed domain to craft an email address can also be detected by examining an SPF record of a given mail that would usually indicate whether a mail comes from a legitimate domain or not.

6) PHONE NUMBER

Some SE attack scenarios involve the use of text messages or phone calls. The use of SMS APIs or SMS Gateways enables attackers to spoof any given phone number easily. That way, the victim's phone will indicate that a particular message has

been sent by a legitimate sender, such as a bank, delivery service or even police or authorities. It is a very effective SE technique, especially given the fact that it is cheap and not technically sophisticated [36].

On the level of an individual person, the only effective countermeasure stems from security awareness and vigilance.

7) PROPS AND WARDROBE

In some cases, enacting a fake identity or impersonating someone may involve acquiring appropriate props and wardrobe. Such items serve to enhance the credibility of the assumed cover story. For instance, if the attacker pretends to be a food delivery worker, they would be expected to have the usual objects possessed by such people, like the delivery bag with the logo of a food delivery company, sometimes also some t-shirts or jackets with the company logo, etc. The same may apply to many other scenarios, such as acting as a police officer (which would require at least a fake police ID and may require a fake uniform) or pretending to be a construction worker (helmet and reflective jacket required). Usually, acquiring these items is not difficult, as most of them are available in the most popular online markets.

D. INITIAL CONTACT

In this phase, the attacker enters into the first interaction with the victim. The attacker can confront the information gathered during the reconnaissance and the victim's psychological profile with reality. It is also the first test of the credibility of the cover story, fake identity, and resources crafted during the preparation phase. It can provide the attacker with valuable *feedback*, which in turn could prompt them to reiterate back to reconnaissance or preparation in order to enrich, modify, or alter their intelligence, plans, or scenarios.

There are different means of communication which the attacker can use to initiate contact with the victim. Similarly to techniques listed in other phases of SE attack, they do not exclude each other and can be mixed or used concurrently. Each of them has some unique characteristics, advantages, and disadvantages in terms of costs, difficulty, OPSEC risks, influence on building credibility and trust, the scope of interaction with the victim, etc. Typically, these characteristics constitute a trade-off between the efficacy of a given method on the one hand and its costs (counted in the required time, effort, skills, and money) on the other hand.

1) EMAIL

Using emails to contact the victim is often associated with *classic* phishing tactics. Emails as a means of communication have several significant advantages for the attackers. They are cheap (if not free at all) to send. It is easy to scale and automate the process of sending them, i.e., with the use of Social Engineering Toolkit [37] or GoPhish [38], especially when the messages are sent to multiple recipients [9]. The rise of Large Language Models (LLMs) and other AI-enabled

technologies that could automatically generate personalized phishing (or spear phishing) messages may provide a further boost in the use of emails for SE attacks, both targeted and conducted *en masse* [11]. Emails also do not pose a high OPSEC risk, and a basic OPSEC setup, such as VPNs, VPSes, and virtualization methods, is generally sufficient to remain anonymous online.

However, emails also have some disadvantages. Due to the fact that email phishing has been present in the cybersecurity threat landscape since the nineties and it is still the most frequently used technique, the threat awareness concerning email phishing among the public (hence, among potential victims) is rising [9]. Moreover, emails are a somewhat *impersonal* means of communication, meaning that they leave a certain distance between the victim and the attacker. The nature of emails, being more formal than text messages, for example, does not fully support cutting this distance. Especially in the era of AI-enabled chatbots, when the recipient of the email cannot be sure if it is a real person or a machine on the other side of the conversation. Furthermore, unlike phone/voice calls (see subsection on phone/voice call), emails do not always require an instant response from the victim, thus giving some time to reconsider the actual contents and context of the phishing email. This forces the attacker to put more effort into inspiring trust (or other intended emotions - more on that subject in the section on establishing a rapport) or invest in a volume of messages sent to seek economies of scale.

Potential defensive mechanisms against this technique are - depending on a particular scenario - a combination of those linked with fake and legitimate accounts, impersonation or domain spoofing, and typosquatting [8].

2) PHONE/VOICE CALL

One of the most remarkable advantages of using Phone Call (or Voice Call, as technically it does not necessarily have to be done by phone - for the sake of simplicity of language, we will use these two terms interchangeably) is that it introduces a sense of instant urgency for the victim and usually urges the victim to take some actions in real-time while speaking with the attacker on the phone. Therefore it diminishes the time and space for the victim to think and analyze the content of the attacker's message or request, persuading the victim to act instantly [36].

This technique is also relatively cheap and technically easy to execute. However, it requires more preparation than using email or text messages. First and foremost, the attacker needs to be able to communicate verbally in the language (most preferably a native tongue) of the victim. The less fluently the attacker can verbalize the message in a given language, the lower the chances of sustaining the credibility of the scenario. This fact largely influences the geographical scope of the use of Phone Call technique on the part of the attacker.

In terms of potential OPSEC risks, the most significant one is linked to the use of the attacker's own voice. In case the potential victim records such a conversation, it can provide

the law enforcement with substantial evidence. However, tracking these phone calls is very difficult, especially if the attacker has some OPSEC protocols in place.

The AI-based solutions, namely *deepfakes audio*, are opening an entirely new frontier in using voice calls for SE attacks [39]. Imitating the voice of a person who is well-known to the victim in order to deliver the message can render voice-based Social Engineering even more effective than before.

Perhaps the most efficient countermeasure is security awareness and attempting to verify the identity of the caller through other means, e.g. in case of phone calls from the supposed bank officials it is recommended to disconnect and contact the bank individually to verify the authenticity of the initial call.

3) VIDEO CALL

Video calls are very similar to voice calls in regard to underlying psychological mechanisms. They share the same advantages of imposing the urgent need for reaction in real-time from the victim [40].

These two techniques also share most of their disadvantages, such as the potential language barrier. Furthermore, if the attacker stands personally before the camera of the video call, they risk compromising their appearance.

Video *deepfakes* may revolutionize the video calls as a SE attack technique [39]. Some more cautious or cyber-aware people may always come with some dose of mistrust, even to voice calls from a seemingly known person. However, it would require a nearly paranoid level of cautiousness not to trust a person whom one can not only hear but also see. The far-reaching philosophical and epistemological implications of that phenomenon are a potential subject for a different paper or debate.

The defensive mechanisms are similar to the ones related to phone calls.

4) TEXT MESSAGES

The use of text messages (i.e., SMS) for Social Engineering is most commonly linked with smishing. It shares many characteristics with emails. SMS is cheap, and sending them in bulk is easy to scale and automate [41].

Compared to emails, text messages are somewhat more *direct* and encourage the recipients to react to them faster. However, especially when sent *en masse*, SMS may seem to appear *impersonal*, similar to emails, therefore requiring more effort to convince the victim to perform the intended action or sending more messages in pursuit of economies of scale.

On the level of an individual user, the best response to that technique is remaining vigilant. Telecommunication providers have the capability to limit the volume of such messages. However, these institutional interventions would not be effective against the use of text-messages-like communicator applications, e.g. WhatsApp or Signal.

5) SOCIAL MEDIA

Using Social Media Platforms for communication is similar to using emails with respect to ease of use, scaling, and automation.

It also has one crucial advantage over the use of email. If the attacker uses a social media account that looks authentic, it boosts the attacker's credibility and trustworthiness. From the perspective of the victim, the person using a legitimate account with one's name, photo, personal details, etc., seems to be less dubious. On the other hand, creating and maintaining a social media account might be effort and time-consuming (which is discussed in Section IV-C2).

Scrutinizing the potential attacker by running some background checks with the reverse use of OSINT and SOCMINT could generally be a good practice in order to verify the identity and - to some extent - intentions of a person initiating a contact through social media [26].

6) IN PERSON

Meeting with a potential victim in person is definitely the most risk-generating method for the attacker to expose them personally. It also requires highly developed interpersonal skills, a considerable amount of preparation, and usually some appropriate props (i.e., fake ID cards, business cards, clothes, etc., in accord with the cover story).

Despite the risks and requirements of this method, entering into direct interaction with the victim in person yields some significant advantages.

First, with the use of a good cover story backed up with appropriate props and influence techniques (further discussed in the section on establishing a rapport), this method allows to build a very high level of credibility and trustworthiness on the part of the attacker.

Second, it gives the attacker an excellent chance to collect first-hand observations on the victim's demeanor and behavior, enabling the attacker to further enrich the intelligence collected during the reconnaissance, particularly the psychological profile of the victim.

Given the potential level of nuances and variants associated with this technique, it is difficult to point out one definitive countermeasure that would be effective in this case. Similarly to nearly every SE TTP, some sort of security awareness and vigilance is always a good choice, but it does not cover the whole spectrum of risks related to that particular technique.

7) REVERSE SOCIAL ENGINEERING

Reverse Social Engineering denotes inspiring the victim to initiate contact with the attacker through any means of communication listed above [6]. In terms of the complexity of execution, it is perhaps the most demanding method of initial contact for the attacker. Creating a situation and environment in which the victim themselves, either on their own initiative or under the influence of manipulation from the attacker, would initiate the communication might require considerable expenditures of effort, time, and - more often

than not - creativity. It also transfers some control over the initial momentum of the SE attack process from the attacker to the victim.

Giving the victim some control (even if the control is, in fact, illusory) is both one of the most significant drawbacks of this method and the root of its most important advantage. In general, the victim is much less prone to exhibit distrust towards the attacker due to a cognitive bias - meaning distortions in a view of reality or in a rationality of a judgment [7] - in the victim's perception that it was them (the victim) who found and chose the attacker, not the other way round, essentially rendering establishing the rapport much easier for the attacker.

Similarly to the case described in Section IV-B7, the defensive mechanisms against this technique would vary depending on the particular scenario and could comprise the countermeasures described in all of the techniques from this phase.

E. ESTABLISHING A RAPPORT

A rapport, a term originating from psychology, should be understood as having an emotional connection between two (or more) people (in this case, between the attacker and the victim) [42].

Establishing a rapport is perhaps one of the most nuanced and - at times - elusive phases of the SE attack. It may sometimes seem, for instance, in one-stage phishing or smishing scenarios, that it is difficult to distinguish between the initial contact, establishing a rapport, and exploitation, as they are more or less part of the same message. The differentiation between them is much easier in longer or multi-stage schemes. However, even in the shortest examples of Social Engineering attacks, it is possible to point out some aspects of establishing a rapport between the attacker and the victim.

The reason why initial contact stage should be treated separately from the phase of establishing a rapport is that the latter, no matter how brief it shall be, constitutes essentially the psychological and cognitive core of Social Engineering process, whereas the former is more of a technical nature, though, as outlined previously, it does have an impact on the psychological and cognitive part of the SE process.

The main objective of the attacker in this stage is to instill or inspire certain emotions or cognitive biases in the victim, in order to make the victim more susceptible to influence or outright manipulation, which is of the essence in the exploitation phase - where the attacker seeks to convince the victim to usually perform some action. Establishing a rapport - an emotional link - with the victim lowers the victim's risk perception and assertiveness, which renders accomplishing the attacker's objectives much more accessible [7].

In the following subsections, we will attempt to outline the key methods, mechanisms, and factors that contribute to building trust or at least willingness to comply with the attacker's intent. In particular, we will

refer to two frameworks developed by the theory of human intelligence [43], namely MICE (Money, Ideology, Coercion/Compromise, Ego) and RASCLS (Reciprocation, Authority, Scarcity, Commitment/Consistency, Liking, Social Proof), which is heavily inspired by Cialdini's influence principles [14]. These two frameworks can be treated as mutually complementary, although they also overlap to some degree. Nonetheless, the practical experiences of human intelligence experts demonstrate the usefulness and efficiency of both of them in building a rapport in order to recruit or convince a person to perform some actions [43]. We will also try to show how methods from MICE and RASCLS translate to real-life techniques employed by threat actors in Social Engineering attacks.

1) MICE

MICE covers four basic incentive types - Money, Ideology, Coercion, and Ego. Historically, it is the first framework developed to categorize psychological drivers for influencing people within the field of human intelligence [43]

- 1) **Money** - It is rather self-explanatory why money - or other materialistic stimulus, as it does not necessarily have to take the form of *pure* cash - may be effective. In general, people seek to improve their well-being, and a potential financial reward is one of the ways to achieve that goal.
A baiting technique, in which the attacker uses a false promise as bait to entice the victim to perform some action (e.g., text messages informing of a fake lottery win), is a perfect example of using money as a primary driver for building trust.
- 2) **Ideology** - This motivation applies to people with strong beliefs or convictions who put great importance on them. It is primarily used to appeal to a person's political or religious stance, especially if that stance renders that person disgruntled or dissatisfied with their current situation or surroundings [43].
- 3) **Coercion/Compromise** - This method is based on fear of being exposed, humiliated, or compromised. That fear constitutes a powerful stimulus, however - unlike previous ones - it is predominantly negative in nature. Blackmail is one of the most notable methods associated with coercion. The attacker uses a threat of exposing some information, which could, for instance, cause some damage (financial, emotional, reputational, etc.) to the victim, in order to convince them to comply with the attacker's intents [7].
Other noteworthy methods associated with fear are extortion or intimidation.
An excellent example of using coercion as a SE method is instilling fear in the victim by using text messages informing of an overdue or unpaid invoice.
- 4) **Ego** - Similar to money, it serves the purpose of improving one's well-being, but - unlike money - it is primarily about mental well-being, satisfying

the psychological needs for, i.e., acknowledgment, attention, reward, or even revenge.

Using flattery and compliments in interaction is a common way to appeal to one's ego, in particular to the need for acknowledgment and feeling important.

2) RASCLS

RASCLS is heavily inspired by the works of Cialdini [14] and covers six categories of influence principles: Reciprocation, Authority, Scarcity, Commitment, Liking, and Social Proof.

- 1) **Reciprocation** - Reciprocation can be described as a psychological urge to respond to kindness with kindness [44]. Also, human helpfulness relies on this principle to some extent. People tend to be helpful because they might believe that their positive behavior and attitude would entice others to behave in a similar manner.

An influence method known as *Quid Pro Quo* is a direct derivative of the reciprocation principle. The attacker presents the victim with a promise to do something important or valuable for the victim in exchange for prior compliance with the attacker's instructions (e.g., taking some action or disclosing some information) [6].

- 2) **Authority** - In general, people are much more likely to listen to or follow a person who has some authority or power or is respected [44]. This explains the effectiveness of the use of cover stories such as police officers, network/security administrators, and bank employees - all of these positions are rather universally associated with authority and due respect.

Pretexting, which denotes the use of pretenses, fake identity, or impersonation in order to persuade the victim to conform to the attacker's intents [6], often takes advantage of the authority principle to provide an additional layer to credibility and attractiveness of the pretenses used.

- 3) **Scarcity** - The scarcity principle uses the mechanism of inducing a victim with a sense of urgency or time constraints for some action or decision. Limiting the time also limits the ability to analyze the situation thoroughly, thus urging the victim to act on instincts or impulses rather than on logic and reason [44], in fact often making the victim act in a state of *bounded rationality* [45].

Messages informing a victim of exclusive, time-limited discounts or offers are a perfect example of employing the scarcity principle.

On a side note, a psychological and philosophical question of the limits of rationality within a decision-making process in the context of SE attack should indeed be another important subject for research in this area.

- 4) **Commitment** - This principle takes advantage of the psychological need to be self-consistent. This usually means that once people commit to some decision, they

are much more likely to stand by that decision rather than change their view [44].

The foot-in-the-door method is one of the best examples of putting the commitment principle to use. In this technique, the attacker makes several minor requests over some period of time in order to finally present the victim with the actual large request. The victim, willing to stay consistent with the already made commitments, is more prone to comply with the given request [6].

- 5) **Liking** - Similarly to authority, people are more prone to trust and agree with someone if they have developed a sense of liking for that person in the first place [14], [44].

A special case of this technique is the Honey Trap, which is aimed at leveraging a romantic affection in order to build and consequently exploit the victim's trust.

- 6) **Social Proof** - Social Proof refers to the fact that some (real or imaginative) majority of people, most preferably in similar circumstances or situations, believe in something to be true or right [43]. In essence, it comes down to convincing the victim to perform some action because *everyone else does it* or it is *socially preferred*. This principle is particularly effective if the victim is faced with new or unfamiliar circumstances. In such cases, people tend to observe other humans in order to determine what is the appropriate or acceptable behavior [43].

In practice, this could manifest as information that thousands of people have already benefited from a specific offer or discount. This impact can be further enhanced by including endorsements from well-known individuals or organizations, for example.

3) META-PRINCIPLE: INTERNAL AND EXTERNAL CONSISTENCY OF THE COVER STORY

Apart from all the methods enumerated above, there is also one *meta-principle* essential for building a rapport - the internal and external consistency of the cover story. The internal consistency refers to the cover story itself, which has to be logical and must not contain internal contradictions. The external consistency relates to how well the cover story fits with the given circumstances and environments.

The consistency between the chosen fake identity, together with its cover story, and the demeanor and external appearance, both in the physical and the virtual world, is essential in building credibility [44]. For example, when pretending to be a police officer, the attacker should not only present some required props (e.g., fake police ID) but also act in a way the police officers are expected to behave by the general public. Otherwise, the inconsistencies of the entire cover story might draw the victim's attention, rendering them more suspicious and, in consequence, less prone to trust or believe the attacker. The same applies to any given cover story. The more inconsistencies there are, the more likely it is for the victim to compromise that cover.

4) COUNTERMEASURES

Due to the psychological nature of this phase of the attack, effective mitigation mechanisms revolve around psychological aspects of human behavior as well. Identifying techniques of psychological influence or manipulation is often not a trivial task, even for professionals with some background in psychology. Therefore, developing universal countermeasures against influence techniques based on MICE or RASCLS frameworks seems to be a task exceeding the capabilities of modern day science.

F. EXPLOITATION

From the perspective of the attacker, this is perhaps the most critical stage of the Social Engineering attack. All the effort from the previous phases leads to exploiting the victim in this one - which essentially takes the form of successfully convincing the victim to perform a specific action intended by the attacker. From the point of view of the victim, exploitation usually marks a *point of no return*, irreversibly compromising the security of information targeted by the attacker.

As a side note, it should be underlined that in some cases, the attacker might actually want the victim not to undertake some actions. Thus, *performing an action* should be understood collectively as both acting and refraining from taking an action, as long as it is in line with the intentions of the attacker.

A list of several types of action desired by the attacker can be distinguished, which are further explored in the following subsections.

1) DISCLOSE CREDENTIALS

Convincing the victim to disclose credentials could potentially provide the attacker with instant access to otherwise unavailable resources [9]. Especially if the Multi-Factor Authentication is not in place.

Eliciting credentials from the victim can be achieved, i.e., by providing the victim with a URL to a legitimately-looking fraudulent login page to a given service or platform. The victim, convinced to be logging in to a legitimate service, thus discloses the credentials in plain text to the attacker, who can then use them to access and - in some cases - obtain control of such an account.

Introducing mechanisms like, e.g., multi-factor authentication, alongside identity and access management systems, network segmentation, and comprehensive incident response procedures [8], [20] could minimize or mitigate the potential damages caused by disclosing the credentials to the attacker.

2) DISCLOSE SENSITIVE INFORMATION

Another type of the attacker's objectives can be associated with accessing or stealing sensitive or confidential information. In such scenarios, the attacker would primarily attempt to entice the victim to share such data, either consciously or not [6], [44].

Although gaining access to the victim's accounts or resources, i.e., by convincing the victim to disclose credentials, in some cases, might equal obtaining access to sensitive information, these two objectives are not always convergent. First of all, the information desired by the attacker might not be accessible via the victim's account. In fact, it may not even exist in an electronic form, i.e., being written on physical paper or passed solely verbally. Second, accessing the victim's account usually leaves some forensic traces (logs, IP addresses, behavioral patterns, etc.), while collecting such information directly from the victim might not leave any electronic traces at all (for instance, if it is done through meeting the victim in person).

Procedures such as network segmentation or need-to-know policy limit the scope of data accessible to a particular individual within an organization, thus mitigating the impact of a potential incident [20].

3) MALWARE DEPLOYMENT

The attackers who are capable of developing appropriate malware - or at least using some existing ones, such as payloads available in Metasploit Framework [46] or Cobalt Strike [47] - might aim at using the victim as an *entry point* for delivering such files to the target host or network and further executing it [6].

Technological solutions like Extended Detection and Responses (XDR) or Security Orchestration, Automation, and Response (SOAR) systems and network segmentation, together with incident response procedures, could constitute effective countermeasures in that scenario [8], [20].

4) PROVIDING ACCESS TO RESTRICTED DATA OR INFRASTRUCTURE

The victim can also be regarded as a sort of *entry point* for accessing restricted data, resources, or infrastructure [44]. Though similar results can be achieved, for instance, by inducing the victim to disclose credentials or executing a malicious file, this point is much broader. Access to otherwise restricted resources does not have to be provided online or electronically. It can also take the form of physical access (e.g., by delivering physical keys, entry cards, etc., to the attacker).

Tailgating and piggybacking are perfect examples of techniques aimed at physically accessing restricted areas. These are methods used to gain physical access to otherwise restricted areas by following an individual with legitimate access [7]. Typically, it might be mixed with an impersonation or fake identity of a food delivery service or a new employee of an organization. In tailgating, the individual with legitimate access is not aware of the fact that the attacker has gained access to the area, whereas, in piggybacking, that individual is aware of the attacker's presence but assumes that the attacker possesses a legitimate reason to be there (e.g., as a food delivery service).

Physical security procedures, as well as Identity and Access Management systems, are the most efficient countermeasures against such attacks [8].

5) PROVIDING ACCESS TO OTHER INDIVIDUALS

Due to the position of the victim within the target organization or group, the victim might also be a *proxy* in reaching another individual who would otherwise be unreachable or hard to reach for the attacker. In that scenario, the attacker would be aiming to persuade to contact (i.e., via mail, phone, or text message) a third party. For instance, it could be a part of devising a reverse social engineering scenario aimed at that person in order to entice them - through a message from the primary victim - to initiate contact with the attacker.

Need-to-know policy and security awareness of the users are the most important mechanisms aimed at mitigating that technique.

6) TRANSFER MONEY

It is no secret that a vast fraction of Social Engineering attacks are motivated by the prospect of financial rewards for the attacker. Hence, in some schemes, the attacker might be looking for ways to persuade the victim straightforwardly to transfer money to the attacker.

On the level of an individual, security awareness gives the best protection against such attacks. However, financial institutions, like banks, can introduce some further procedural mechanisms, e.g. preventing potential victims from transferring large sums of money to attackers or from suddenly withdrawing substantial funds from bank accounts.

G. POST-EXPLOITATION

After successfully exploiting the victim, the attacker might seek various options, depending mainly on the main objective of a particular SE attack scenario. Basically, these can be divided into two major groups:

- 1) Further exploitation or actions,
- 2) Terminating the contact.

In both cases, the attacker has several techniques and objectives available to use listed below.

1) FURTHER EXPLOITATION OR ACTIONS

This is applicable most notably when the attacker is pursuing some long-term objectives. In that case, the attacker might seek to use the already established rapport to make further use of the victim's capabilities, position, etc., in order to gain more profits in addition to the ones achieved during the exploitation phase. Examples of such benefits could be:

1) **Disclose further sensitive or confidential information**

This is the case primarily within the schemes where the attacker's prime objective is linked with espionage or stealing sensitive information. Once the victim has been engaged in cooperation with the attacker, the victim is generally more prone to disclose additional information [43].

Potential countermeasures are identical to the ones described in Section IV-F2

2) **Exfiltration of information**

The human factor can be used not only for gaining access and infiltration but also for the exfiltration of information. MITRE ATT&CK Matrix acknowledges this fact by including a relevant technique (T1052 - Exfiltration over physical medium) in its Exfiltration Tactics [3]. Using the victim's capability to save the intended information on a physical medium and physically carrying it away may be particularly useful in cases where the outbound traffic of the target's network/infrastructure is heavily monitored or restricted. Defensive mechanisms enumerated in Section IV-F2, complemented by physical security procedures, seem to be the most effective against this technique.

3) **Provide additional backdoor or foothold**

The victim's position and capabilities might be used to establish some form of additional backdoor or foothold for the attacker within the targeted network. This may take the form of, i.e., providing the attacker with legitimate credentials to remote access services (such as Remote Desktop Protocol, VPN, etc.).

This point can also be interpreted in the context of Social Engineering itself and the notion of the reiteration loop of the SE process. Successfully exploiting an individual for a specific objective using certain methods does not always mean that such a victim would be willing to automatically comply with other intents of the attacker (especially if they are significantly different from the previous ones). However, with the use of all the information collected during the initial SE attack, the attacker might come back to some of the earlier phases of the attack and seek alternative ways of exploiting that person.

This goal of the attacker can be mitigated, e.g., with network segmentation, incident response procedures, and other mechanisms described in Sections IV-F1, IV-F2 and IV-F3.

2) TERMINATING THE CONTACT

On the other hand, achieving the objectives from the exploitation phase might suffice to accomplish the attacker's goals. In such cases, the attacker would normally seek the termination of the contact with the victim because there would be no interest in continuing it. Moreover, due to the fact that the attacker's actions are usually legally dubious (if not outright illegal), sustaining the communication with the victim might actually be used by the victim or law enforcement to collect criminal evidence.

Terminating contact can be done in several ways, depending on the given scheme, previous actions, and the attacker's potential objectives for the future:

1) **Abrupt Termination**

That notion is rather self-explanatory and denotes the cases in which the attacker terminates contact with the

Reconnaissance	Preparation	Initial Contact	Establishing a Rapport	Exploitation	Post-Exploitation
OSINT	Fake Identity	Email	Money	Disclose Credentials	Disclose Further Information
SOCMINT	Fake Accounts	Phone/Voice Call	Ideology	Disclose Sensitive Information	Exfiltration of information
Data Leaks	Legitimate Accounts	Video Call	Coercion	Downloading or Executing a Malicious File	Provide additional backdoor or foothold
Public Records	Impersonation	Text Messages	Ego	Providing Access to Restricted Data	Abrupt Termination
Dumpster Diving	Typosquatting and Domain Spoofing	Social Media	Reciprocation	Providing Access to Other People	Swift Termination and Covering Tracks
Darknet	Phone Number	In Person	Authority	Transfer Money	Options for Future Contact
Social Engineering for Reconnaissance	Props and Wardrobe	Reverse Social Engineering	Scarcity		
			Commitment		
			Liking		
			Social Proof		

FIGURE 2. Social engineering TTPs matrix.

- victim after achieving the intended objectives during the exploitation phase.
- 2) **Swift Termination and Covering Tracks**
- In other instances, the attacker might actually be looking to gradually extinguish the rapport and the communication with the victim. This approach is usually more subtle and allows for some sort of covering up the tracks, sometimes even leaving the victim unaware of the fact of being the target of a Social Engineering attack.
- 3) **Leaving Options for Future Contact**
- This is applicable primarily to the scenarios that assume some potential long-term goals, but there is no real need for sustaining an active and on-going rapport or contact with the victim.

H. PUTTING ALL ELEMENTS TOGETHER

Having described in detail all the elements of the proposed framework, it is time to put them all together into one comprehensive and legible form. As outlined in the opening sections of this paper, the main goal of this work is to create a framework suitable for the analysis of Social Engineering attacks similar to MITRE ATT&CK or Cyber Kill Chain. Hence, in Figure 2, we propose a matrix-like form to illustrate the entire framework described in the previous sections.

The idea behind the proposed matrix form of the framework is inspired by the MITRE ATT&CK, which has already proven that this form provides a decent degree of transparency and legibility. Including only short names of the techniques (with links to a detailed description in a separate location) gives a good overview of the entire process without overwhelming the reader with too much information in one

place but supplying the reader with an easily accessible option to dive deeper into the details of a particular method. As such, it can also be easily implemented in designing security controls, which justifies its usefulness.

SE attacks generally follow the path marked out by the six phases mentioned above, regardless of available skills, know-how, or technical resources. We acknowledge the fact that there might exist some Social Engineering TTPs that are not already known or have not been brought to our attention. Given the fact that the matrix form of the framework provides a great deal of flexibility and openness, it is easy to fit any unknown or not included techniques into this matrix, further developing and extending it without affecting the core assumptions underlying the framework. This feature is aimed at providing a framework that would be long-lasting in the ever-evolving cybersecurity landscape. The advent of new technologies, particularly AI-enabled tools, might - and probably will - influence the methods used by the attackers. However, it will likely not affect the general and rather universal SE attacks workflow, following the six stages mentioned previously from reconnaissance to post-exploitation.

I. TECHNICAL TOOLS AND RESOURCES

This section is devoted to providing a summary of technical tools and resources that can be used during each phase of the SE attack process. This overview might not be fully exhaustive, as there is a plethora of various tools and specialized software, which are constantly evolving and changing. Some of them might cease to exist in the future or may lose their potential due to changes in the cybersecurity landscape. Other tools may, in turn, appear in place of the

old ones. Therefore, this summary is by no means aimed at providing a definitive list of Social Engineering tools. It is rather supposed to serve as an example.

1) RECONNAISSANCE TOOLS

The variety of tools that could be used for different aspects of reconnaissance is very broad, and we will name just a handful of the most popular ones covering various features of information gathering [22].

- 1) Maltego - an OSINT framework for automating information gathering. It contains an option for visualization of the collected information, i.e., in the form of a graph illustrating the links between different entities and pieces of data [48].
- 2) FOCA - which stands for Fingerprinting Organizations with Collected Archives, enables the attacker to retrieve metadata and hidden information from files or documents like PDFs, Microsoft Office, or Open Office formats [49].
- 3) Google Hacking Database (GHDB) - is a collection of *Google dorks* - advanced search operators - which enhance the accuracy of the search results returned by search engines, Google in particular [50].
- 4) theHarvester - a tool for collecting email addresses, domain names, subdomains, IP addresses, etc. [51].

2) PREPARATION TOOLS

It is difficult to point out explicit software frameworks used in the preparation phase. Techniques such as creating a fake identity, typosquatting, or generating a phone number rely on particular, usually legitimate, services available online. Creating fake accounts also takes advantage of valid options and features within social media platforms or email providers' services. Acquiring appropriate props and wardrobe does not require any particular technical resources.

3) INITIAL CONTACT TOOLS

There are a few publicly available tools and frameworks designed for conducting phishing and other Social Engineering attacks. Although they are primarily crafted for penetration testers, some of these tools are also known to be used *out in the wild* by malicious actors.

- 1) Social Engineering Toolkit (SET) - an open-source framework for conducting and automating various types of customizable Social Engineering attacks, like phishing, spear phishing, etc. [37].
- 2) GoPhish - an open-source framework for enacting phishing attacks [38].
- 3) Cobalt Strike - a commercial penetration testing framework for emulating different types of adversaries and their TTPs. Apart from options to i.a. generate customizable payloads, it incorporates SET together with its capabilities, which makes it a powerful tool for technically oriented social engineering scenarios [47].

- 4) Metasploit Framework - a well-known framework for penetration tests, in-built by default in the penetration testing Linux distribution - Kali Linux. It can be integrated with SET to craft and automate phishing and spear phishing attacks [46].

4) ESTABLISHING A RAPPORT TOOLS

Due to the psychological nature of this phase, it is difficult to point out technical tools or resources useful for building an emotional link between the attacker and the victim. However, with the current rapid development of LLMs and Generative Adversarial Networks (GANs), it cannot be ruled out that AI-enabled tools will be used for facilitating and optimizing the interaction with the victim based on their psychological and behavioral profile (for instance, based on the information collected during the reconnaissance), especially given the fact that some LLMs are claimed to have already passed the Turing test.

5) EXPLOITATION TOOLS

The set of tools used in the exploitation phase depends largely on the attacker's objectives. In the case of the *technical* objectives, it is possible to enumerate several examples of available resources.

- 1) Cobalt Strike - the wide variety of in-built exploit generation options gives the attacker a lot of exploitation possibilities, including establishing a Command and Control server [47].
- 2) Metasploit Framework - similarly to Cobalt Strike, Metasploit offers a broad selection of exploit generation and execution, as well as establishing a communication channel [46].

6) POST-EXPLOITATION TOOLS

The potential resources used in this phase are more or less identical with the ones used in the exploitation stage of the attack.

V. COMPARISON TO OTHER EXISTING FRAMEWORKS

In order to demonstrate the level of innovation presented by this framework, it is worth comparing it to some of the already existing frameworks. That would emphasize the new elements, aspects or notions introduced by this framework, thus outlining the added value of this paper.

For that purpose, we will provide a comparison of the techniques and methods enumerated in this paper with the most important framework in the cybersecurity landscape, namely the Cyber Kill Chain [4] and the MITRE ATT&CK matrix [3], which were already invoked a handful of times in this paper. To do that, we will iterate through each stage and method from our framework, and we will try to find a corresponding technique from these two frameworks.

A. COMPARISON TO CYBER KILL CHAIN

The general outline of the framework presented in this paper is very similar to the approach represented by Cyber Kill

Chain, especially in the preparatory stages of the attack. Both frameworks contain phases of Reconnaissance and Preparation/Weaponization. The phase of Initial Contact is more or less equivalent to the phase of Delivery from the Cyber Kill Chain. However, due to the specific nature of SE attacks, significant differences between these two frameworks occur at the later stages of the attack process. It is rather difficult to draw direct analogies between them, especially in regard to the phase of Establishing a Rapport, which highlights the distinguishable character of the framework presented in this paper.

Moreover, Cyber Kill Chain does not offer a detailed breakdown of each phase into particular TTPs. We believe that presenting these TTPs in detail constitutes one of the most important sources of added value brought by the Social Engineering Analysis Framework, rendering it more actionable for an analysis of real-life scenarios.

B. COMPARISON TO MITRE ATT&CK

1) RECONNAISSANCE

- 1) OSINT - MITRE ATT&CK contains a couple of techniques that can be collectively treated as OSINT and its derivatives. These techniques are: T1589 (Gather Victim Identity Information), T1591 (Gather Victim Organization Information), T1593.002 (Search Open Websites/Domains: Search Engine), T1593.003 (Search Open Websites/Domains: Code Repositories), T1594 (Search Victim-Owned Websites).
- 2) SOCMINT - T1593.001 (Search Open Websites/Domains: Social Media).
- 3) Data Leaks - there is no direct equivalent, although the description T1593.002 (Search Open Websites/Domains: Search Engine) refers to data links to some extent.
- 4) Public Records - no direct equivalent, however, to some extent, this method could be regarded as partially covered by T1589 (Gather Victim Identity Information), T1591 (Gather Victim Organization Information) and T1593 (Search Open Websites/Domains).
- 5) Dumpster Diving - no direct equivalent.
- 6) Darknet - although there is no direct equivalent of this method, T1593.002 (Search Open Websites: Search Engine) could, to some limited extent, also correspond to the use of the Darknet.
- 7) Social Engineering for Reconnaissance - MITRE ATT&CK enumerates only the potential use of phishing and spear phishing to gather information with its T1598 (Phishing for Information). Meanwhile, the method outlined in this paper is much broader, as it refers to the full spectrum of Social Engineering attacks, not just phishing and spear phishing, which could be used as a reconnaissance for another attack.

2) PREPARATION AND WEAPONIZATION OF INFORMATION

- 1) Fake Identity - there is no direct equivalent to creating a fake identity, nor a cover story themselves, although

there are techniques corresponding with certain aspects of such an identity/cover story, like creating fake accounts.

- 2) Fake Accounts - T1585 (Establish Accounts) refers to creating email accounts as well as social media or cloud accounts.
- 3) Legitimate Accounts - T1586 (Compromise Accounts) refers to obtaining access to compromised email or social media accounts.
- 4) Impersonation - T1656 (Impersonation).
- 5) Domain Spoofing and Typosquatting - T1538.001 (Acquire Infrastructure: Domains) refer to both Typosquatting and Domain Spoofing.
- 6) Phone Number - no equivalent.
- 7) Props and Wardrobe - no equivalent.

3) INITIAL CONTACT

- 1) Email - T1566.001 (Phishing: Spear Phishing Attachment) and T1566.002 (Phishing: Spear Phishing Link) collectively refer to the use of email as a means of contact in SE attack.
- 2) Phone/Voice Call - T1566.004 (Phishing: Spear Phishing Voice).
- 3) Video Call - no direct equivalent.
- 4) Text Messages - no direct equivalent.
- 5) Social Media - T1566.003 (Phishing: Spear Phishing via Services).
- 6) In Person - no direct equivalent.
- 7) Reverse Social Engineering - no direct equivalent.

4) ESTABLISHING A RAPPORT

This entire phase is left out by the MITRE ATT&CK, owing to the fact that MITRE ATT&CK is primarily technology-centered in terms of defining attacker's TTPs. The notion of building a rapport between the attacker and the victim is only briefly mentioned in a detailed description of T1566.003 (Phishing: Spear Phishing via Services); however, the authors do not delve into details.

5) EXPLOITATION

- 1) Disclose Credentials - T1056 (Input Capture) refers mainly to the same notion of capturing credentials voluntarily disclosed by the victim.
- 2) Disclose Sensitive Information - although there is an entire section devoted to the collection of information in the MITRE ATT&CK (TA0009 - Collection), there is no specific technique referring to the victim actually voluntarily disclosing the sensitive information other than credentials without resorting to some technical resources like keyloggers.
- 3) Downloading and/or Executing a Malicious File - the most relevant equivalent within the MITRE ATT&CK is T1204 (User Execution)
- 4) Providing Access to Restricted Data or Infrastructure - there is no equivalent referring to actual physical access to restricted data or infrastructure.

- 5) Providing Access to Other Individuals - T1534 (Internal Spear Phishing) partially covers the scope of this method, but it is by no means exhaustive, as it does not refer to providing access to other individuals by means other than phishing.
- 6) Transfer Money - T1657 (Financial Theft)

6) POST-EXPLOITATION

- 1) Further Exploitation: Disclose further sensitive or confidential information - similarly to the Disclose Sensitive Information method during the exploitation phase, there is no clear equivalent within the MITRE ATT&CK.
- 2) Further Exploitation: Exfiltration of Information - T1052 (Exfiltration over Physical Medium) is at least partially equivalent to that method.
- 3) Further Exploitation: Additional backdoor or foothold - T1078 (Valid Accounts) covers the topic of using access to legitimate accounts to compromise the security of the target organization. Access to such accounts may be obtained through Social Engineering attack.
- 4) Terminating the Contact: Abrupt Termination - no precise equivalent.
- 5) Terminating the Contact: Swift Termination and Covering Tracks - no precise equivalent.
- 6) Terminating the Contact: Leave Option for Future Contact - no precise equivalent.

7) COMPARISON SUMMARY

Figure 3 depicts the overview of the comparison in a graphical way. As can be observed, there are several methods within the framework proposed in this paper that are not covered by the MITRE ATT&CK framework, thus leaving potential security gaps. This proves that there is indeed space and a need for a new approach to comprehend Social Engineering attacks and, hopefully, design better defense mechanisms against them.

One possible way to integrate the presented framework with the MITRE ATT&CK would be to enrich the equivalent TTPs from the MITRE ATT&CK with the data from this framework or, in case there is no relevant entry within the MITRE ATT&CK matrix, add new records denoting the techniques described in this paper. This approach would definitely require further work and research in order to ensure full consistency between the two frameworks. However, since the MITRE ATT&CK is primarily focused on the technical side of information security, simply adding the TTPs defined in this article to that matrix might actually blur the overview of SE attacks. In particular, in this paper, we have put a great emphasis on perceiving these attacks as a process. Splitting it into atomic elements and adding to a bigger framework, such as MITRE ATT&CK, might lead to losing that context in a potential analysis. Therefore, an alternative approach is worth considering. Due to the distinctive nature of SE attacks, it might be worthwhile to retain a separate framework dedicated to them, similarly to,

e.g., the DISARM framework [52] devoted to the analysis of disinformation and misinformation operations. On one hand, it is heavily inspired by the methodology and formulation of the MITRE ATT&CK, benefiting from a clear and actionable structure offered by MITRE. On the other hand, the DISARM framework is focused on a very specific type of malicious activities, which justifies why this framework should be kept separate from other frameworks. The case with SE attacks could be similar, as some of them are aimed at goals lying beyond the scope of the MITRE ATT&CK, employing TTPs not included in it at all. Thus, treating the framework presented in this paper as a tool that complements other, already existing ones seems to provide the greatest degree of synergy in analyzing the TTPs of the particular threat actors in a manner similar to how the Diamond model [53] complements the Cyber Kill Chain and the MITRE ATT&CK.

VI. APPLYING THE FRAMEWORK TO REAL-LIFE SCENARIOS

The value of any tool is a function of its practical usefulness. It applies also to the framework (which, in essence, is nothing but a tool for a structured analysis) proposed in this paper. Therefore, in order to provide proof of usefulness, this section contains two examples of real-life Social Engineering scenarios together with their analysis conducted in accordance with the approach from this paper.

The examples represent three very distinctive scenarios. One, designed and executed by supposedly high-end experts with long-term goals and aimed at high-level targets. The second is prepared and conducted by people without high-end logistic resources, with very short-term goals and aimed primarily at low-level targets. And the third, which incorporated some of the latest technological developments as tools to execute an attack scenario. The variety in the chosen examples is supposed to provide proof that the framework proposed in this paper provides a comprehensive approach for analysis of Social Engineering attacks, no matter what their target is and how *professionally* they are designed, prepared, and executed.

A. CHINA'S LinkedIn ESPIONAGE

1) BRIEF SUMMARY OF THE PLOT

In 2023, several British news outlets, such as BBC [54], [55], The Times [56] or The Guardian [5], informed that over 20,000 Britons working for various branches of the government, public sector, think-tanks or organizations with close ties to the public sector, have been targeted by alleged Chinese spies, supposedly linked with the Chinese Ministry of State Security.

The Chinese used LinkedIn to identify and approach the targeted individuals with seemingly neutral business cooperation proposals. At first, the orders seemed relatively *innocent*. In the long run, they were supposed to provide a ground for gaining sensitive or confidential

Social Engineering Analysis Framework matrix comparison with the MITRE ATT&CK matrix					
Reconnaissance		Preparation		Initial Contact	
Social Engineering Analysis Framework	MITRE ATT&CK	Social Engineering Analysis Framework	MITRE ATT&CK	Social Engineering Analysis Framework	MITRE ATT&CK
OSINT	T1589, T1591, T1593.002, T1593.003, T1594	Fake Identity	no direct equivalent, but mentioned in T1585	Email	T1566.001, T1566.002
SOCMINT	T1593.001	Fake Accounts	T1585	Phone/Voice Call	T1566.004
Data Leaks	T1593.002	Legitimate Accounts	T1586	Video Call	-
Public Records	T1589, T1591, T1593	Impersonation	T1656	Text Messages	-
Dumpster Diving	-	Typosquatting and Domain Spoofing	T1538.001	Social Media	T1566.003
Darknet	T1593.002	Phone Number	-	In Person	-
Social Engineering for Reconnaissance	T1598 - partially	Props and Wardrobe	-	Reverse Social Engineering	-
Establishing a rapport		Exploitation		Post-Exploitation	
Social Engineering Analysis Framework	MITRE ATT&CK	Social Engineering Analysis Framework	MITRE ATT&CK	Social Engineering Analysis Framework	MITRE ATT&CK
Money	-	Disclose Credentials	T1056	Disclose Further Information	-
Ideology	-	Disclose Sensitive Information	-	Exfiltration of information	T1052
Coercion	-	Malware Deployment	T1204	Provide additional backdoor or foothold	T1078
Ego	-	Providing Access to Restricted Data	-	Abrupt Termination	-
Reciprocation	-	Providing Access to Other People	T1534 - partially	Swift Termination and Covering Tracks	-
Authority	-	Transfer Money	T1657	Options for Future Contact	-
Scarcity	-				
Commitment	-				
Liking	-				
Social Proof	-				

FIGURE 3. Social engineering TTPs matrix - comparison with the MITRE ATT&CK matrix.

information from the targets [54]. Some targeted individuals have also been offered additional remuneration for information on people employed in the British intelligence agencies [54].

The media pointed out at least one known alias used in this campaign - "Robin Zhang". He acted as a representative of a consulting company from China. According to The Times [56], the details of his company were unclear or *vague*.

In some cases, the targets were also invited to China, in return for considerable compensation, where they often were subject to more direct actions, such as honey trapping and blackmail, sometimes combined together [54], in order to force the targets to disclose the intended information.

It is worth noting that this plot is a perfect example of a scenario which results in compromising the security of information without resorting to nearly any of the TTPs outlined in MITRE ATT&CK matrix [3].

2) DECOMPOSITION OF THE SCENARIO

Having outlined the general overview of the discussed scenario, we can step on to decompose it into the particular elements of the process in accordance with the idea of the aforementioned framework.

1) Reconnaissance

SOCMINT: It seems to be obvious that social media are one of the core axes of this scenario. Undoubtedly, SOCMINT has been extensively used for targeting, reconnaissance, and collecting data on the targeted individuals (victims). LinkedIn seems to be a primary source of knowledge, but it cannot be ruled out - in fact, it appears to be very likely - that other social media platforms have been used to enrich the target's profile and craft a more individualized approach during the preparation phase.

OSINT: With utmost certainty, it can be stated that OSINT has been used by the threat actor to complement the information gathered from SOCMINT. The *digital culture* in the United Kingdom is relatively open, thus there is no shortage of potential OSINT sources that could be leveraged to collect information on people and organizations.

Public Records: Given the fact that public registries, such as company registry [57], are publicly available online in the UK, it is likely that they have been used to gather more information on business and personal links between targeted organizations and entities.

In the outcome of this phase, the attacker was able to identify potentially vulnerable individuals with access to sensitive or confidential information, as well as build a psychological profile of these individuals.

2) Preparation

Fake Identity: At least one bogus identity has been identified to be used in this scenario, though it is probable that there were multiple such identities. Fake

identities have been further enriched by creating a fake company.

Fake Accounts: Identified fake identities have been paired up with their respective social media accounts, together with fake company accounts, that were supposed to add another layer of depth.

Fake identities and accounts created during this phase were used to both provide a platform for initial contact and build up a credible cover story tailor-made for particular targets.

3) Initial Contact

Social Media: LinkedIn is a primary known means of communication used by the attacker in this scenario.

The use of LinkedIn - which is a business-oriented social media platform - as a medium of communication was aimed at convincing the victims that they are presented with a legitimate business offer, presented by a *real* person, representing a *real* company.

4) Establishing a Rapport

Money: The purported business nature of the offers made by the threat actor in this scenario clearly emphasized the financial rewards linked with the potential cooperation.

Commitment: The attacker's *modus operandi* of gradually engaging the targets in the seemingly legitimate business cooperation before making an actual request for disclosing sensitive information is an accurate illustration of the Foot-in-the-Door technique.

Liking: This technique - more specifically, honey trapping - has supposedly been used against individuals who accepted invitations to China.

Coercion: Some of the targets who agreed to travel to China were also subject to blackmail, sometimes linked with their prior engagement in a honey trap.

The result of this phase was the creation of a link between the threat actor and their target. The rapport was primarily based on materialistic incentives, with a considerable amount of money being offered in exchange for cooperation. In some cases, this was further reinforced by the fear of being exposed or compromised.

5) Exploitation

Disclose Sensitive Information: Most of the targets were asked or persuaded to disclose sensitive or confidential information.

Providing Access to Other Individuals: In some of the reported cases, the targets were exploited to gain access to other individuals, especially those employed in the British intelligence agencies.

6) Post-Exploitation

Further Exploitation: Given the long-term nature of the attacker's goals, the successfully exploited victims were most likely subject to further exploitation in order to gain access to a broader scope of confidential information. This was also a case in a similar scenario in the USA [58].

B. POLICEMAN SCHEME

1) BRIEF SUMMARY OF THE SCHEME

The fake policeman scheme is a scam scenario popular in numerous countries, including the UK and the USA. There are multiple variations of this scam with differences in details [59], [60]. However, based on the large number of incidents following this suite, it is possible to distinguish certain core features of this scheme, which are present in most of its variations.

In general, the attackers tend to target elderly people, whose perception of the world, and technology in particular, is more likely to be limited, distorted, or vulnerable to influence or manipulation [59].

The attacker usually contacts the victim by phone, introducing one's self as a police officer. With the use of false pretenses, for instance, by claiming that the victim's bank account is likely to be the subject of a hacker attack, the attacker convinces the targeted individuals to transfer their money to a supposedly *safe* account managed by the police in order to prevent it from being stolen [60].

In order to boost the victim's perception of the attacker's credibility, the attacker often invites the victims to actually call the police themselves in order to confirm the attacker's identity. The attacker pretends to terminate the phone call by playing sound, signaling the disconnection of the call without actually disconnecting. The victim, unaware of the fact that the original phone call was not terminated, tries to call the police. Being still within the same connection, the victim starts a conversation with another attacker, who acts as a police dispatch. That attacker confirms the identity of the primary caller as a police officer [59].

The victim, if successfully persuaded to follow the scenario, is convinced to be dealing with the police officers and is likely to comply with their requests to transfer money (in some cases, the attacker might even appear in person to collect the money from the victim) [59]. Having received the money, the attackers usually terminate the contact definitely.

As mentioned before, this scam scenario has several variations, particularly in terms of the pretenses used, but they all follow more or less the same pattern. Noteworthy, on the part of the attackers, this scenario is technically not complicated, and it does not require any special tools or technical skills. Nevertheless, it proved to be very effective, given that on several occasions, the victims lost considerable amounts of money, counted thousands or even hundreds of thousands of Euros.

2) DECOMPOSITION OF THE SCHEME

Similarly to the previous scenario described in this paper, we will now proceed to present a decomposition of this scam into particular phases in line with the methodology presented before:

1) Reconnaissance

Data Leaks: Data leaked from banks, e-commerce platforms, and social media are most likely being used

to identify individual targets that could be vulnerable, i.e., due to their age.

OSINT: Though it is not confirmed, it is quite likely that OSINT serves as a complementary source of information about the target.

SOCMINT: Similarly to OSINT, there is no definitive confirmation of SOCMINT being used for reconnaissance in this scenario, but it is very possible. Especially given the fact that SOCMINT might provide some valuable information about the victim's relatives and family.

As a result, the attacker is able to identify a potential victim, together with their personal data, age, and sometimes even some details concerning their bank accounts, etc.

2) Preparation

Fake Identity: The attacker uses a fake identity of the police officer, sometimes backed up with appropriate props, such as a fake police ID.

Phone Number: In some cases, the attackers are known to be using spoofed or bogus phone numbers to reinforce their OPSEC.

Creating a fake identity used in this scheme does not involve much effort or preparation on the part of the attacker, especially if no physical interaction with the victim is planned.

3) Initial Contact

Phone Call: Using a phone call to initiate contact with the victim, apart from being convenient, is aimed at introducing an element of urgency.

4) Establishing a Rapport

Authority: Using the cover story of a police officer refers directly to the Authority principle

Coercion: The attacker usually uses some elaborate pretenses or threats (i.e., the inbound hacker attack or a relative being held in custody [59]) to provide a credible justification for the request to transfer money.

Scarcity: The attacker frequently imposes time pressure on the victim by insisting that the pretenses or threats used are time-limited.

In this scenario, the rapport with the victim is formed instantly with the use of fear of losing financial resources as a stimulus mixed with several influence principles. This scheme is an illustrative example of blending together the Authority (acting as a police officer - a figure that should be obeyed and listened to) and Scarcity (giving the victim a very limited time to respond) principles.

5) Exploitation

Transfer: The sole goal of the attacker is to persuade the victim to transfer the money.

6) Post-Exploitation

Terminating the Contact: Once the money is transferred, the attackers usually terminate the contact rather abruptly without further explanation, which often renders the victims aware of

the fact that they have been exploited by the attacker.

C. DEEPFAKE VISHING

1) BRIEF SUMMARY OF THE PLOT

In February 2024, CNN reported that one of the employees of a Hong Kong office of the Arup company had fallen victim to a SE attack that employed advanced deepfake technology [39].

First, the victim received an email signed by the company's chief financial officer (CFO) asking for a money transfer of 25 million USD. The employee suspected that the email was a phishing attempt and initially refused to comply with the demand. Then, the attackers initiated a video conference with the targeted individual. Several people from top-tier executives of the company, including the CFO, attended the online meeting and confirmed that the request for the money transfer was legitimate. Having received a confirmation on video from known executives, the employee authorized the transfer. In the post-incident analysis, it turned out that all of the people attending the online video meeting were deepfaked on both visual and audio layers, which was enough to convince the victim to trust them.

2) DECOMPOSITION OF THE SCENARIO

Following the suite outlined in the previous examples, we will attempt to decompose this scenario with the use of the framework presented in this paper:

1) Reconnaissance

OSINT: Undoubtedly, the attacker devoted a great deal of effort to collecting data about the hierarchy and inner structure of the target company, most likely with the use of OSINT. The attackers also had to gather video and audio samples of the individuals that were later used to create deepfakes.

SOCMINT: Due to the vast availability of photographs and video recordings on social media platforms, it is likely that SOCMINT was used to collect data necessary for the creation of video deepfakes.

2) Preparation

Impersonation: The attackers most likely had access to legitimately looking (but not necessarily legitimate) mail accounts. They also prepared materials for creating deepfake videos of selected individuals.

3) Initial Contact

Email: The reports by CNN suggest that the victim was contacted via two channels. First the target employee received an email, Due to the fact that it did not suffice to achieve the adversaries goals, they had a contingency plan in a form of a video call.

Video Call: The choice of a video call was probably dictated by the fact that it seemed to be the most trustworthy means of communication from the viewpoint of the victim, especially given the prior suspicious email.

4) Establishing a Rapport

Authority: The attackers primarily used the factor of authority, acting as the victim's superiors.

5) Exploitation

Transfer Money: Based on the media reports, the sole goal of the attackers was to convince the victim to authorize money transfers.

6) Post-Exploitation

Terminating the Contact: Having achieved the goal of the attack, the adversaries terminated the contact with the victim without ensuring any potential ways for further contact.

D. CONCLUSION ON DECOMPOSITION

The above-mentioned examples illustrate the practical use of the framework proposed in this paper. As it is shown, this framework can be used to decompose SE attacks into *prime elements*, providing an in-depth insight into the entire process of the attack, both before and after the actual incident.

Noteworthy, the framework remains valid regardless of the objectives or the sophistication and complexity of the methods used by the attacker, which constitutes perhaps its most significant added value.

VII. SUMMARY AND DISCUSSION

This paper presents a comprehensive framework for the analysis of Social Engineering TTPs. It provides an insight into the entire process of SE attacks, dividing it into six consecutive phases: reconnaissance, preparation, initial contact, establishing a rapport, exploitation, and post-exploitation. Each of them is described in detail, with particular regard to the respective techniques and methods used during each stage. To emphasize the innovative character of this framework, it is compared to the MITRE ATT&CK. The number of Social Engineering TTPs which are not covered by MITRE ATT&CK shows that the current approach to Social Engineering threats is not sufficient. Furthermore, the practical application of the framework is demonstrated by applying it to decompose and analyze two entirely different real-life scenarios.

There is no doubt that there is still plenty of room for future studies in Social Engineering. First of all, this framework is aimed at aiding in designing and introducing more effective means of defense against SE attacks. Particularly in the context of the growing use of AI-enabled solutions in SE attack scenarios, which is likely to spur yet another surge in the number of such incidents. Further research on cognitive and psychological aspects underlying various SE techniques might help devise more accurate defense mechanisms, especially on an *individual* level.

Moreover, several other aspects within this paper deserve a separate discussion, such as, i.a., the implications of the notion of bounded rationality in the decision-making process on the efficiency of some of the SE techniques.

Perhaps the most prominent area for further research would be an attempt to integrate the approach presented in this paper with the wider context of processes involved in executing

cyberattacks. SE attacks are often only a part of a broader attack pattern, being just one of the stages of the process underlying cybersecurity incidents. However, the extent of research required to conduct such an integration exceeds the limitations of this paper, making it an interesting topic for a separate article.

Another worthwhile avenue for future studies could be an endeavor to draw and quantify some of the most common SE attack paths based on the TTPs matrix presented in this paper. It would involve considerable data collection and quantitative research, which would again be a suitable material for an independent paper.

Nevertheless, the idea presented in this paper might be a good starting point for such studies, which itself would be an added value of this paper.

REFERENCES

- [1] Z. Wang, L. Sun, and H. Zhu, "Defining social engineering in cybersecurity," *IEEE Access*, vol. 8, pp. 85094–85115, 2020, doi: [10.1109/ACCESS.2020.2992807](https://doi.org/10.1109/ACCESS.2020.2992807).
- [2] S. Venkatesha, K. R. Reddy, and B. R. Chandavarkar, "Social engineering attacks during the COVID-19 pandemic," *SN Comput. Sci.*, vol. 2, no. 2, p. 78, 2021, doi: [10.1007/s42979-020-00443-1](https://doi.org/10.1007/s42979-020-00443-1).
- [3] MITRE ATT&CK. MITRE Corporation. Accessed: Feb. 6, 2024. [Online]. Available: <https://attack.mitre.org/matrices/enterprise/>
- [4] Lockheed Martin. *Lockheed Martin Cyber Kill Chain*. Accessed: Feb. 6, 2024. [Online]. Available: <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>
- [5] *The Guardian*. Accessed: Feb. 6, 2024. [Online]. Available: <https://www.theguardian.com/uk-news/2023/oct/17/up-to-20000-britons-approached-by-chinese-agents-on-linkedin-says-mi5-head>
- [6] R. Montanez and S. Xu, "Cyber social engineering kill chain," in *Proc. 4th Int. Conf., SciSec, Matsue, Japan, Aug. 2022*, pp. 487–504.
- [7] R. Montanez, A. Atyabi, and S. Xu, "Social engineering attacks and defenses in the physical world vs. cyberspace: A contrast study," in *Cybersecurity and Cognitive Science*. Cambridge, MA, USA: Academic, 2022.
- [8] M. Zaoui, B. Yousra, S. Yassine, M. Yassine, and O. Karim, "A comprehensive taxonomy of social engineering attacks and defense mechanisms: Towards effective mitigation strategies," *IEEE Access*, vol. 12, pp. 72224–72241, 2024, doi: [10.1109/ACCESS.2024.3403197](https://doi.org/10.1109/ACCESS.2024.3403197).
- [9] Z. Alkhalil, C. Hewage, L. Nawaf, and I. Khan, "Phishing attacks: A recent comprehensive study and a new anatomy," *Frontiers Comput. Sci.*, vol. 3, Mar. 2021, Art. no. 563060, doi: [10.3389/FCOMP.2021.563060](https://doi.org/10.3389/FCOMP.2021.563060).
- [10] *Spearphishing, Understanding the Threat*, Center for Protection Nat. Infrastructure, London, U.K., 2023.
- [11] J. Hazell, "Spear phishing with large language models," 2023, *arXiv:2305.06972*.
- [12] B. Bowen, S. Hershop, A. Keromytis, and S. Stolfo, "Baiting inside attackers using decoy documents," in *Security and Privacy in Communication Networks*. Berlin, Germany: Springer, 2009, pp. 51–70, doi: [10.1007/978-3-642-05284-2_4](https://doi.org/10.1007/978-3-642-05284-2_4).
- [13] K. Mitnick and W. Simon, *The Art of Deception: Controlling the Human Element of Security*. Hoboken, NJ, USA: Wiley, 2002.
- [14] R. Cialdini, *Influence: The Psychology of Persuasion*. New York, NY, USA: Bus. Library, 1984.
- [15] C. Hadnagy, *Social Engineering: The Science of Human Hacking*. Hoboken, NJ, USA: Wiley, 2018, doi: [10.1002/9781119433729](https://doi.org/10.1002/9781119433729).
- [16] S. Widup, A. Pinto, D. Hylender, G. Bassett, and P. Langlois, "Verizon data breach investigations report," Verizon, New York, NY, USA, Tech. Rep. DBIR2021, 2021. [Online]. Available: [https://doi.org/10.1016/S1361-3723\(21\)00061-0](https://doi.org/10.1016/S1361-3723(21)00061-0)
- [17] L. Iacono, K. Wojcieszek, and G. Glass, "Q3 threat Landscape report," Kroll, New York, NY, USA, Tech. Rep., 2023.
- [18] S. Widup, A. Pinto, D. Hylender, G. Bassett, and P. Langlois, "Social engineering report," Proofpoint, Sunnyvale, CA, USA, Eng. 2022. Accessed: Feb. 7, 2024. [Online]. Available: https://www.proofpoint.com/sites/default/files/threat-reports/Proofpoint_Threat_Research_Social_Engineering_Report_2022.pdf
- [19] *The HackerNews*. Accessed: Feb. 7, 2024. [Online]. Available: <https://thehackernews.com/2023/11/how-multi-stage-phishing-attacks.html>
- [20] M. Coole, "Defence in depth, protection in depth and security in depth: A comparative analysis towards a common usage language," in *Proc. 5th Austral. Secur. Intell. Conf.*, 2012, pp. 1–10.
- [21] V. Mair, *The Art of War: Sun Zi's Military Methods*. New York, NY, USA: Columbia Univ. Press, 2007. [Online]. Available: <http://www.jstor.org/stable/10.7312/zi-13382>
- [22] *Open-Source Intelligence*, Dept. Army, Arlington County, VA, USA, 2021.
- [23] M. Nobili, "Review OSINT tool for social engineering," *Frontiers Big Data*, vol. 6, Sep. 2023, Art. no. 1169636, doi: [10.3389/fdata.2023.1169636](https://doi.org/10.3389/fdata.2023.1169636).
- [24] *OSINT Framework*. Accessed: Feb. 9, 2024. [Online]. Available: <https://osintframework.com/>
- [25] *OSINT Industries*. Accessed: Feb. 2, 2024. [Online]. Available: <https://osint.industries>
- [26] D. Omand, J. Bartlett, and C. Miller, "Introducing social media intelligence (SOCMINT)," *Intell. Nat. Secur.*, vol. 27, no. 6, pp. 801–823, Dec. 2012, doi: [10.1080/02684527.2012.716965](https://doi.org/10.1080/02684527.2012.716965).
- [27] L. Cheng, F. Liu, and D. D. Yao, "Enterprise data breach: Causes, challenges, prevention, and future directions," *Wiley Interdiscip. Rev. Data Min. Knowl. Discov.*, vol. 7, no. 5, 2017, Art. no. e1211, doi: [10.1002/widm.1211](https://doi.org/10.1002/widm.1211).
- [28] *Pastebin*. Accessed: Feb. 12, 2024. [Online]. Available: <https://pastebin.com/>
- [29] R. Weaver and R. J. Cazier, "Dumpster diving: A study on data recovery and exploitation," in *Proc. Southeast Inst. Oper. Res. Manag. Sci.*, 2007, pp. 1–4.
- [30] Z. Omar and J. Ibrahim, "An overview of darknet, rise and challenges and its assumptions," *Int. J. Comput. Sci. Inf. Technol.*, vol. 8, no. 3, pp. 110–116, 2020.
- [31] B. Jones, "The 21st Century DarkNet market: Lessons from the fall of silk road," *Int. J. Cyber Criminol.*, vol. 10, no. 1, pp. 40–61, 2016, doi: [10.5281/zenodo.58521](https://doi.org/10.5281/zenodo.58521).
- [32] *Fake Name Generator*. Accessed: Feb. 12, 2024. [Online]. Available: <https://www.fakenamegenerator.com/>
- [33] M. H. Yilmaz and H. Arslan, "Impersonation attack identification for secure communication," in *Proc. IEEE Globecom Workshops (GC Wkshps)*, Dec. 2013, pp. 1275–1279, doi: [10.1109/GLOCOMW.2013.6825169](https://doi.org/10.1109/GLOCOMW.2013.6825169).
- [34] J. Spaulding, D. Nyang, and A. Mohaisen, "Understanding the effectiveness of typosquatting techniques," in *Proc. 5th ACM/IEEE Workshop Hot Topics Web Syst. Technol.*, Oct. 2017, pp. 1–8, doi: [10.1145/3132465.3132467](https://doi.org/10.1145/3132465.3132467).
- [35] N. Tripathi, M. Swarnkar, and N. Hubballi, "DNS spoofing in local networks made easy," in *Proc. IEEE Int. Conf. Adv. Netw. Telecommun. Syst. (ANTS)*, Dec. 2017, pp. 1–6, doi: [10.1109/ANTS.2017.8384122](https://doi.org/10.1109/ANTS.2017.8384122).
- [36] H. W. Park, J. B. Kim, and M. J. Bae, "Prevention of voice phishing through analysis of telephone call voice characteristic," *Int. J. Eng. Technol.*, vol. 7, no. 3, pp. 62–66, Aug. 2018, doi: [10.14419/ijet.v7i3.33.18525](https://doi.org/10.14419/ijet.v7i3.33.18525).
- [37] *Social Engineering Toolkit*. Accessed: Feb. 13, 2024. [Online]. Available: <https://github.com/trustedsec/social-engineer-toolkit>
- [38] *GoPhish*. Accessed: Feb. 14, 2024. [Online]. Available: <https://getgophish.com>
- [39] CNN. *Finance Worker Pays Out \$25 Million After Video Call With Deepfake 'Chief Financial Officer'*. Accessed: Apr. 3, 2024. [Online]. Available: <https://edition.cnn.com/2024/02/04/asia/deepfake-cfo-scam-hong-kong-intl-hnk/index.html>
- [40] S. Biswal, "Real-time intelligent vishing prediction and awareness model (RIVPAM)," in *Proc. Int. Conf. Cyber Situational Awareness, Data Anal. Assessment (CyberSA)*, Jun. 2021, pp. 1–2, doi: [10.1109/CYBERSA52016.2021.9478240](https://doi.org/10.1109/CYBERSA52016.2021.9478240).
- [41] M. L. Rahman, D. Timko, H. Wali, and A. Neupane, "Users really do respond to smishing," 2022, *arXiv:2212.13312*.
- [42] Z. G. Baker, E. M. Watlington, and C. R. Knee, "The role of rapport in satisfying one's basic psychological needs," *Motivat. Emotion*, vol. 44, no. 2, pp. 329–343, Apr. 2020, doi: [10.1007/s11031-020-09819-5](https://doi.org/10.1007/s11031-020-09819-5).
- [43] R. Burkett, "An alternative framework for agent recruitment: From MICE to RASCLS," *Stud. Intell.*, vol. 57, no. 1, pp. 1–13, 2013.
- [44] M. A. Siddiqi, W. Pak, and M. A. Siddiqi, "A study on the psychology of social engineering-based cyberattacks and existing countermeasures," *Appl. Sci.*, vol. 12, no. 12, p. 6042, Jun. 2022, doi: [10.3390/app12126042](https://doi.org/10.3390/app12126042).
- [45] H. Simon, *Utility and Probability*. London, U.K.: Palgrave Macmillan, 1990, doi: [10.1007/978-1-349-20568-4](https://doi.org/10.1007/978-1-349-20568-4).

- [46] *Metasploit Framework*. Accessed: Feb. 16, 2024. [Online]. Available: <https://www.metasploit.com/>
- [47] *Cobalt Strike*. Accessed: Feb. 16, 2024. [Online]. Available: <https://www.cobaltstrike.com/>
- [48] *Maltego*. Accessed: Apr. 4, 2024. [Online]. Available: <https://www.maltego.com/>
- [49] FOCA. *Fingerprinting Organizations with Collected Archives*. Accessed: Apr. 4, 2024. [Online]. Available: <https://github.com/ElevenPaths/FOCA>
- [50] *Google Hacking Database*. Accessed: Apr. 4, 2024. [Online]. Available: <https://www.exploit-db.com/google-hacking-database>
- [51] *TheHarvester*. Accessed: Apr. 4, 2024. [Online]. Available: <https://github.com/laramies/theHarvester>
- [52] *DISARM Framework*. Accessed: Nov. 28, 2024. [Online]. Available: <https://www.disarm.foundation/framework>
- [53] S. Caltagirone, A. Pendergast, and C. Betz, "The diamond model of intrusion analysis," *Threat Connect*, vol. 298, pp. 1–61, Jul. 2023, doi: [10.13140/RG.2.2.31143.56481](https://doi.org/10.13140/RG.2.2.31143.56481).
- [54] BBC. *'Chinese Spy' Targeted Thousands Over LinkedIn*. Accessed: Feb. 20, 2024. [Online]. Available: <https://www.bbc.com/news/uk-66599376>
- [55] BBC. *M15 Head Warns of 'Epic Scale' of Chinese Espionage*. Accessed: Feb. 20, 2024. [Online]. Available: <https://www.bbc.com/news/uk-67142161>
- [56] *The Times*. Accessed: Feb. 20, 2024. [Online]. Available: <https://www.thetimes.co.uk/article/chinese-spy-linkedin-investigation-dxtq8mz7w>
- [57] *U.K. Company Registry*. Accessed: Feb. 20, 2024. [Online]. Available: <https://find-and-update.company-information.service.gov.uk/>
- [58] *New York Times*. Accessed: Feb. 20, 2024. [Online]. Available: <https://www.nytimes.com/2019/08/27/world/asia/china-linkedin-spies.html>
- [59] *Bedfordshire Police*. Accessed: Feb. 20, 2024. [Online]. Available: <https://www.beds.police.uk/news/bedfordshire/news/2023/03-march/warning-issued-following-police-impersonation-scams/>
- [60] *Gloucestershire Police*. Accessed: Apr. 4, 2024. [Online]. Available: <https://www.gloucestershire.police.uk/cy-GB/news/gloucestershire/gloucestershire-constabulary-warns-of-scam-phone-calls-from-fake-police-officers/>

WOJCIECH NOWAKOWSKI is a graduate of University of Warsaw and Warsaw School of Economics.

Currently working as a Cybersecurity Researcher at NASK - National Research Institute. During his professional career he took part in a variety of commercial projects concerning i.e., threat intelligence, applications of AI in cybersecurity and red teaming, with a special focus on social engineering. He is responsible for conducting research in the area of broadly understood cybersecurity, especially linked with the security of the Internet of Things and threat intelligence. His research interests revolve around subjects, such as threat intelligence, social engineering, human factor in cybersecurity, and game theory.

• • •